ADR-07 — Eliminação de conta

Architecture Decision Record · Projeto Steely · Escola de TI · UniCesumar

Status	☒ Proposto ☐ Aceito ☐ Rejeitado ☐ Substituído pelo ADR-___	**Data**	01/11/2026
Responsável	Augusto Palma Guglielmi	**Sprint**	Entrega até 23/11 (Sprints 15 a 17)
Participantes	Augusto Palma Guglielmi, Fabrício Notoya Thomas, Pietro Pasqual Silva, Rafael Tudela Rizental, Thiago Lopes Martins		
Vínculos	STY010 (RN01 a RN05) · RF-02 · PRM-10 e PRM-63 · RNF-03 e RNF-11 · LGPD arts. 16 e 18 · Marco Civil art. 15 · ADR-04, ADR-05, ADR-10, ADR-11, ADR-16 e ADR-23		

1. Contexto

O titular pode pedir a eliminação dos seus dados (LGPD, art. 18). A STY010 já define: a exclusão é bloqueada se houver transação, leilão ou reclamação em andamento (RN01) ou saldo de moedas (RN02); existe carência de 30 dias para reativação (RN04 e PRM-10); depois da efetivação o perfil público é anonimizado e os dados sujeitos à retenção legal são preservados (RN05). Falta decidir **como**: anonimização irreversível ou exclusão física, e o que fica.

Há uma tensão real: o **ledger de moedas é imutável** (ADR-10), os logs são append-only (ADR-05) e os registros fiscais precisam de 5 anos (PRM-63). Excluir fisicamente tudo quebraria a imutabilidade e a obrigação legal. A LGPD permite conservar dados para cumprimento de obrigação legal (art. 16, I).

Já definido pelo grupo: o ADR-16 prevê varredura diária de "carência de exclusão e expurgo em 30 dias" que "anonimiza e elimina". O ADR-08 prevê backup com `pg_dump` a cada 6 horas; o ADR-23 e o ADR-24 definem o armazenamento local do app.

2. Direcionadores da decisão

- **LGPD:** eliminar o que não precisa ser guardado e reter só o exigido por lei.
- **Irreversibilidade real:** sem como reidentificar após o prazo.
- **Integridade:** manter o ledger, os logs e os registros fiscais íntegros.
- **Segurança do usuário:** carência de 30 dias contra exclusão acidental ou por invasão.
- **Esforço até 23/11:** usar a varredura e as funções SQL já previstas.
- **Demonstrabilidade:** mostrar o pedido, a carência e o resultado.

3. Opções consideradas

Opção A — Exclusão física total

Descrição: apagar todos os registros do usuário, inclusive transações, ledger e logs.

Prós:

- Simples de explicar
- Nenhum dado restante

Contras:

- Quebra a imutabilidade do ledger e dos logs
- Viola a guarda fiscal de 5 anos
- Apaga histórico de outras partes (comprador e vendedor)

Opção B — Somente anonimização

Descrição: manter todas as linhas e apenas substituir os campos pessoais por valores genéricos.

Prós:

- Preserva integridade e histórico
- Mais simples

Contras:

- Conserva dado que poderia ser apagado (chat, fotos, contatos)
- Menos aderente ao direito de eliminação

Opção C — Carência, depois exclusão física do que não é obrigatório e anonimização irreversível do restante

Descrição: 30 dias de carência com a conta suspensa; depois, exclui o que não tem obrigação de guarda e anonimiza o vínculo do que precisa ser mantido.

Prós:

- Atende à LGPD e à guarda legal
- Preserva ledger e logs
- Há tempo para reativar

Contras:

- Mais regras e testes
- Exige tabela segregada para os dados fiscais
- Backups ainda contêm o dado por um tempo

4. Decisão

Opção escolhida: C — Carência de 30 dias, depois exclusão física do que não é obrigatório e anonimização irreversível do vínculo do que precisa ser mantido.

Justificativa: é a única opção que atende ao mesmo tempo ao direito de eliminação (LGPD, art. 18) e à obrigação de guarda (art. 16, I), sem quebrar o ledger e os logs imutáveis. A Opção A viola a guarda fiscal e a imutabilidade; a Opção B guarda mais do que o necessário.

Fluxo:

- **Pedido:** o usuário autenticado confirma a ciência das consequências (STY010). O sistema recusa com erro de regra de negócio (RFC 9457, ADR-13) se houver transação, leilão ou reclamação em andamento ou saldo de moedas.
- **Carência (30 dias, PRM-10):** conta em estado EM_CARÊNCIA, com sessões revogadas, anúncios ocultos e login só para reativar. Aviso por e-mail no pedido e 7 dias antes do fim.
- **Expurgo:** a varredura diária do ADR-16 (`sweep_exclusao_30d`) chama `private.anonimizar_usuario(user_id)`, idempotente, que executa a tabela abaixo.

Dado	Tratamento	Motivo
E-mail, telefone, senha, 2FA, tokens de push e de sessão, endereço, foto de perfil	Exclusão física	Sem obrigação de guarda
Conteúdo de chats e mensagens, rascunhos e preferências	Exclusão física	Pode conter dado pessoal (ADR-02 e RF-08)
Fotos do usuário e dos anúncios sem transação ativa	Exclusão física no Storage (ADR-11)	EXIF já removido, mas a imagem pode identificar
Cache local, banco local e chaves no app	Apagados no dispositivo (ADR-23 e ADR-24), também quando a sessão é revogada por EM_CARÊNCIA	Evita dado residual
Avaliações recebidas por terceiros	Mantidas, com o autor exibido como "Usuário removido"	Preserva a reputação de outros usuários
Perfil público (nome, apelido, reputação exibida)	Anonimização irreversível: "Usuário removido"	STY010-RN05
Identificador do usuário em transações, ledger e logs	Mantido como pseudônimo, sem tabela de correspondência	Imutabilidade do ADR-10 e do ADR-05
CPF e dados fiscais das transações	Guardados em tabela segregada, com acesso restrito, por 5 anos; depois eliminados	PRM-63 e obrigação legal (LGPD, art. 16, I)
Logs de acesso	Mantidos até vencer os 12 meses; depois descartados	ADR-05 e Marco Civil, art. 15
Dados do DaaS	Nada a fazer	Já anonimizados e agregados (ADR-04)

Irreversível de verdade: o pseudônimo é um identificador aleatório e **não** deriva do CPF nem do e-mail (um hash de CPF seria reversível por dicionário). Não existe tabela que ligue o pseudônimo à pessoa, exceto a tabela fiscal segregada, que só o perfil de auditoria acessa e que é eliminada em 5 anos.

Backups: os `pg_dump` de 6 h (ADR-08) conterão o dado até serem descartados. A decisão do grupo (ADR-08) é guardar os dumps por no máximo 30 dias, e a eliminação não é retroativa nos backups (informado na política de privacidade).

O resultado fica em `audit.financial_and_dispute_logs` (ADR-05) sem dado pessoal, e o usuário recebe um comprovante.

5. Consequências

Positivas:

- Atende à LGPD e às obrigações legais sem tocar no ledger.
- Carência protege contra exclusão acidental.
- Fluxo demonstrável com avanço de prazo na defesa (ADR-16).

Negativas ou riscos aceitos:

- O identificador pseudônimo permanece em transações, ledger e logs; só deixa de ser reidentificável se a tabela fiscal e os backups forem tratados como descrito.
- Backups mantêm o dado por até 30 dias.
- Usuário com saldo de moedas ou transação em andamento não consegue excluir até regularizar.

O que muda:

- **Banco:** estado EM_CARÊNCIA, tabela fiscal segregada, função `anonimizar_usuario`.
- **Código:** endpoint de pedido e de reativação; varredura diária; apagar cache e chaves no app.
- **Telas:** fluxo de exclusão com carência, aviso e comprovante.

6. Validação

#	Cenário de teste	Resultado esperado
1	Pedido com transação, leilão, reclamação em andamento ou saldo de moedas	Recusado com motivo (STY010-RN01 e RN02)
2	Login no 10º dia da carência	Conta reativada e eliminação cancelada
3	Varredura no 31º dia	Dados pessoais eliminados; perfil "Usuário removido"
4	Varredura rodada duas vezes	Segunda execução não altera nada (idempotente)
5	Procurar CPF, e-mail e telefone em todas as tabelas, exceto a fiscal	Nenhuma ocorrência
6	Conferir o ledger e os logs após o expurgo	Linhas intactas e cadeia de hash válida (ADR-05)
7	Acesso à tabela fiscal por perfil comum	Negado

7. Plano de implementação

#	Tarefa	Responsável (proposta)	Sprint (proposta)
1	Estados da conta, tabela fiscal segregada e migração	Fabrício e Augusto	16
2	`anonimizar_usuario` e regras de bloqueio	Augusto	16
3	Endpoints de pedido e reativação; `sweep_exclusao_30d`	Thiago	16
4	Telas de exclusão, carência e comprovante	Pietro	17
5	Limpeza de cache e chaves no app	Rafael	17
6	Retenção de 30 dias dos backups; teste de varredura de PII	Fabrício e Augusto	17

Responsáveis e sprints seguem o alinhamento final do grupo de 01/11/2026, com entrega até 23/11.

8. Referências

- Regras de negócio STY010 (RN01 a RN05), PRM-10 e PRM-63; RF-02.
- ADR-04 (DaaS), ADR-05 (logs), ADR-08 (backups), ADR-10 (ledger), ADR-11 (imagens), ADR-16 (varreduras), ADR-23 e ADR-24 (dados no app).
- LGPD arts. 16 e 18; Marco Civil art. 15. Modelo MADR: adr.github.io/madr.

Histórico de revisões

Versão	Data	Autor	Alteração
1.0	01/11/2026	Augusto Palma Guglielmi	Versão inicial, em status Proposto
1.1	01/11/2026	Augusto Palma Guglielmi	Alinhamento final do grupo: avaliações mantidas como "Usuário removido", aviso 7 dias antes, limpeza local no app e backups de 30 dias